



Storey — legal compliance map

Honest analysis of laws that apply · risk surface · action plan

Last updated 2026-05-22 · Reviewed by lawyer: NO (pending)

⚠ **This is NOT legal advice.** It's a domain-knowledge map for Karun's awareness and a starting point for a lawyer conversation. Get the Privacy Policy + Terms of Service reviewed by a qualified Indian-law SaaS specialist before publishing on storeyinfra.com or relying on them with paying customers.

The "demo data" illusion

Calling Storey's current data "demo" doesn't change its legal status. The user CSV from 2026-05-20 contains real names, real businesses, real phone numbers (Avinash Chirania of 4Line Constructions, Pranab Gogoi of BuildNE, etc.). Once real PII is being processed, the IT Act 2000 + DPDP Act 2023 + Consumer Protection Act 2019 + Indian Contract Act all apply — regardless of what you call the data internally.

The right framing: "Have I done the minimum required protections?" — not "Is this real or demo?"

Laws that apply right now

Law	What it requires	Enforcement status (May 2026)
DPDP Act 2023 (Digital Personal Data Protection)	Lawful basis for processing · purpose limitation · security safeguards · 72-hour breach notification · user rights (access, correction, deletion, portability)	Phased in; Data Protection Board still being set up. Small operators not yet aggressively pursued, but exposure exists from Day 1.
IT Act 2000 — Section 43A + SPDI Rules 2011	"Reasonable security practices" for sensitive personal data; damages if you fail and cause wrongful loss	Active since 2008. Real cases pursued.
Consumer Protection Act 2019	If a paying customer loses money due to a bug, they can claim	Active — beta status is not a shield
Indian Contract Act 1872	Implied contracts apply even without signed agreements	Active
GST Act + Income Tax	Triggers when first invoice raised + > ₹20L annual turnover for mandatory GST	Triggers at revenue thresholds
Aadhaar Act 2016	Strict — but only triggers if you handle full Aadhaar numbers	Not triggered (Storey masks to last-4)

Risk surface at 12 testers · honest probabilities

Scenario	Worst-case legal cost	Realistic likelihood today
Data breach + DPDP regulatory action	₹10-50L fine	Low (<i>small scale, 2× RLS audited</i>)
Civil claim from contractor (<i>bug caused loss</i>)	₹2-10L damages	Low-medium
Contract dispute with Arun pilot	₹1-2L + reputation	Low
Worker PII exposed (<i>Aadhaar leaks</i>)	DPDP + civil claim	Low if RLS holds, high if it doesn't
Tax / GST scrutiny	Penalty + interest	Very low at zero revenue
Personal liability without Pvt Ltd	Unlimited	High in any of the above scenarios

The pattern: regulatory enforcement probability is low at your scale. The thing that makes the risk *unbounded* is being unincorporated.

The single biggest legal exposure today

No Pvt Ltd = personal unlimited liability.

Any of the above scenarios *before* you incorporate exposes:

- Personal savings, property, vehicle to attachment

- Family's financial future
- No protection of "corporate veil"

The moment you register a Pvt Ltd, every commercial risk gets contained to the company's assets. **This is the single highest-leverage legal action you can take in the next 30 days.**

CA quote for Pvt Ltd registration: ~₹15-25k all-in (DIN + DSC + MCA filings + MOA/AOA). 4-6 weeks. Already on `docs/TODO.md` under P2 → upgrading to **P0**.

What "minimum compliance posture" looks like

Four pieces — each is a one-time setup, then ongoing. Target dates are this week or this month, not this quarter.

1. Pvt Ltd registration — P0 this week

Single highest-leverage action. Converts personal unlimited liability to corporate liability. Engage a Guwahati-based CA familiar with NE-India startup incorporations. Pick a name reservation candidate — *"Storey Infra Pvt. Ltd."* or *"Storey Construction Tech Pvt. Ltd."*. Cost: ₹15-25k all-in.

2. Privacy Policy + Terms of Service — P0 this week

Legally required even pre-DPDP via IT Act SPDI Rules. Drafts saved in `docs/PRIVACY-POLICY-DRAFT.md` + `docs/TERMS-OF-SERVICE-DRAFT.md`. **Have a lawyer review the drafts** (one-time ~₹3-5k) before publishing at `storeyinfra.com/privacy` and `/terms`.

3. Tester consent — light click-through — P1 this week

Add a checkbox during signup:

"I agree to Storey's Terms of Service and Privacy Policy, and acknowledge that Storey is in beta software."

5 minutes of frontend work. Documents consent for DPDP purposes. Store a timestamp in `profiles.consent_at` (single-column migration).

4. Incident response plan — P1 this month

One-page internal runbook covering detection · containment · notification · communication. Draft saved in `docs/INCIDENT-RESPONSE.md`.

What you DON'T need yet • deferred safely

Item	When it matters
DPIA (<i>Data Protection Impact Assessment</i>)	Crossing ~50k users (DPDP "Significant Data Fiduciary" threshold)
Aadhaar Authentication User Agency (AUA) registration	Only if you do Aadhaar e-KYC; you only store last-4, so N/A
ISO 27001 / SOC 2	When enterprise customers demand it (year 2-3)
Cyber-liability insurance	When MRR > ₹5L/month and a major breach would actually bankrupt you
Trademark registration	Already on TODO; matters once brand has value to protect
Data Processing Agreement (DPA) template	First enterprise contract
Cross-border data transfer disclosure	First international customer

Milestone-triggered compliance items

These activate at specific business milestones — not now. Bookmark for future-self.

Milestone	What activates
First paying customer (₹1 invoice)	GST consideration + IT compliance + bookkeeping under Pvt Ltd
₹20L cumulative annual revenue	GST registration mandatory
₹40L revenue	Tax audit threshold (Section 44AB)
First enterprise contract	DPA template needed; SLA terms; vendor security questionnaire
First international customer	Cross-border data transfer disclosure; PDP cross-border rules
50,000+ user accounts	"Significant Data Fiduciary" obligations under DPDP — DPIA, Data Protection Officer, etc.
₹2 cr+ annual revenue	Statutory audit, more rigorous compliance
Worker data > 1,000 individuals processed	Stricter data handling under DPDP
First employee hired	EPF/ESI registration, payroll compliance
First office lease	Stamp duty, registration

Signal-monitoring · re-read this doc when these fire

Signal	What it means	Action
DPDP Rules finalised and Data Protection Board active	Enforcement environment changes overnight	Full lawyer review
First data subject (user) requests deletion	DPDP Right-to-Erasure flow needs testing	Implement deletion workflow if not already
First breach detected (any severity)	Incident response triggers within 72h	Open <code>INCIDENT-RESPONSE.md</code>
Government inspection or notice	Could be IT Act, DPDP, GST, anything	Engage lawyer same day
Customer threatens legal action	Even just emails	Document everything, engage lawyer within 24h
Acquisition / fundraise conversation begins	Due diligence will scrutinise everything in this doc	DD-prep checklist needed

Concrete action this week

1. **Call a CA — Guwahati or wherever you're comfortable.** Ask: *"What does Pvt Ltd registration cost end-to-end? Timeline? Documents needed?"* Get one quote. Decide by Friday.
2. **Email a startup lawyer.** *"I have draft Privacy Policy + Terms of Service for a SaaS in beta. Looking for a one-time review, ~2 hours of your time, before I publish them."* Quote should be ₹3-5k. Get one quote. Decide by Friday.
3. **Have your spouse / one trusted family member know:**
 - The 1Password / password manager master password
 - That Storey is being built and roughly what's exposed
 - Who to contact (your CA, your lawyer) if you're unavailable for 30+ days

That third one is the run-book minimum viable version — and it doesn't need any lawyer or any cost. Just a 10-minute conversation.

The honest closing framing

Most of what's in this doc isn't urgent at 12 testers. The DPDP fines aren't going to land on a small beta. The civil claim risk is low at zero revenue.

The one thing that IS urgent: Pvt Ltd registration. Because that single action converts an *unbounded* personal exposure into a *bounded* corporate exposure. Every other compliance item is much less consequential than that one decision.

If you do nothing else from this doc — make the CA call this week. The rest stacks on that foundation.